QA Exam Portal — Tam Sənədləşmə (v15)

> ***Canlı:*** *https://exam-portal-nine-azure.vercel.app*
> ***Repo:*** *GitHub — Ehtimad/qa-exam-portal*
> ***Son versiya:*** *v15 — Müəllim təyin etmə, 3-yollu qeydiyyat, Brute-force qorunması*

Changelog

v15 (2026-05-05)

- **3-yollu qeydiyyat:** "Tələbə / Müəllim / Digər" seçim düymələri. Müəllim qeydiyyatı zamanı qrup seçimi tələb olunmur; admin təsdiqi gözlənilir.
- **Müəllim qeydiyyatı:** `role = "teacher"` , `emailVerified = null` — admin aktivləşdirənə qədər giriş bloklanır.
- **Tələbə yaratma (müəllim):** Müəllim "/admin/users" panelindən "Tələbə Əlavə Et" düyməsi ilə öz tələbəsini yarada bilir. Yaradılan tələbə avtomatik müəllimə bağlanır.
- **Sual müəllimi (admin UI):** Sual add/edit modalında "Müəllim" dropdown-u — admin istənilən sualı istənilən müəllimə təyin edə bilir.
- **Toplu müəllim təyin etmə:** Suallar cədvəlindən çoxlu seçimdən sonra "Müəllimə Təhkim Et" → dropdown ilə müəllim seçilir → `POST /api/admin/questions/bulk-teacher` .
- **İstifadəçi filter (müəllim):** Admin users səhifəsindəki filter barına müəllim dropdown-u əlavə edildi.
- **CSV import — teacher sütunu:** Son sütun olaraq müəllim e-poçtu və ya ID qəbul edir. E-poçt varsa DB-dən ID-yə çevrilir.
- **CSV şablon:** `teacher` sütunu əlavə edildi; şablon sonda mövcud müəllimləri istinad kimi sıralayır.
- **Brute-force qorunması:** Login cəhdləri `login_rate_limits` cədvəlində izlənilir. 15 dəqiqədə 10 yanlış cəhddən sonra email bloklanır. Uğurlu giriş sayacı sıfırlayır.

v14 (2026-05-05)

- **Dashboard izolyasiyası:** Müəllim admin dashboard-da yalnız öz tələbələrinin say/cəhd/son nəticə statistikasını görür.
- **Blok/İmpersonation məhdudiyyəti:** `UserRow` -a `canBlock` prop əlavə edildi — müəllim başqasını blok edə/impersonate edə bilməz.

v13 (2026-05-04)

- **Müəllim məlumat izolyasiyası (tam):** Teacher yalnız öz yaratdığı sualları, imtahanları, materialları görür. `WHERE teacher_id = session.user.id` bütün resurslarda tətbiq edildi.
- **Soft Delete (hər yerdə):** `exams.deleted_at` , `questions.deleted_at` , `materials.deleted_at` — hard delete tamamilə ləğv edildi.
- **Ownership check pattern:** `getExamAndCheckOwnership()` , `getQAndCheckOwnership()` , `getMaterialAndCheckOwnership()` — 403 (özün deyil) vs 404 (tapılmadı) ayrımı.

v12 (2026-05-04)

- **Multi-tenancy:** `teacher_id` sütunu `users` cədvəlinə əlavə edildi.
- **Qeydiyyat:** Tələbə qeydiyyatı zamanı müəllim seçimi. `/api/teachers` endpoint.
- **Rəy sistemi:** `feedbacks` cədvəli, `/admin/feedback` , `/dashboard/feedback` .
- **Sorğu modulu:** `teacher_forms` + `teacher_form_answers` . Açıq / tək seçim / çoxlu seçim növləri.
- **Real-time mesajlaşma:** Pusher ap2, private kanallar.
- **Bildiriş sistemi:** fərdi/qrup/hamıya, real-time bell ikonu.

- **Material planlaması:** start/end tarix, qrupa görə.

v11 (2026-05-04)

- **Bulk select + exam assignment:** `POST /api/admin/questions/bulk-exam`.
- **Exam dropdown (Add/Edit modal):** multi-select dropdown + chip görünüşü.
- **CSV format sadələşdirildi:** `lecture_id` və `difficulty` şablondan silindi.

v10–v6

- Exam multi-select, pagination, impersonation, PDF export, analitika, real-time arxitektura, fayl strukturu.

---

1. Texniki Stack

Texnologiya	Versiya	Məqsəd
Next.js	15.x	App Router, SSR/SSG
NextAuth	v5 beta	JWT autentifikasiya
Drizzle ORM	0.38.x	Type-safe DB sorğuları
Neon PostgreSQL	Serverless	Əsas verilənlər bazası
Pusher Channels	—	Real-time mesajlaşma + bildirişlər
TailwindCSS	3.x	UI stilləmə
jsPDF + autotable	—	PDF generasiyası
xlsx	—	Excel export
bcryptjs	—	Şifrə hashleme (cost=12)
zod	—	Schema validasiyası

---

2. Rol Sistemi (RBAC)

2.1 Rollar

Rol	Açıqlama	Admin panelə giriş
`student`	İmtahan verir, öz nəticəsinə baxır, materiallar, mesajlar	❌
`admin`	Tam sistemə nəzarət	✅ Tam
`manager`	Suallar, qruplar, imtahanlar, nəticələr, materiallar, elanlar	✅ Geniş
`reporter`	Yalnız nəticələr, analitika, export	✅ Məhdud
`worker`	Sual yükləmə/import, sual idarəsi	✅ Məhdud
`teacher`	Yalnız **öz** tələbələri/sualları/imtahanları/materialları/nəticələri	✅ Məhdud

2.2 İcazə Matriksi (v15)

Funksiya	admin	manager	reporter	worker	teacher
İstifadəçiləri gör/idarə et	✅	❌	❌	❌	✅ (yalnız öz tələbələri)
Tələbə yarat	✅	❌	❌	❌	✅ (öz tələbəsi kimi)
Rol təyin et	✅	❌	❌	❌	❌
İstifadəçini blokla	✅	❌	❌	❌	❌
Impersonation	✅	❌	❌	❌	❌
Sualları idarə et	✅	✅	❌	✅	✅ (yalnız öz sualları)
Sual müəllimsini dəyiş	✅	❌	❌	❌	❌
Toplu müəllim təyin et	✅	❌	❌	❌	❌
Sual import/şablon	✅	✅	❌	✅	❌
Qrupları idarə et	✅	✅	❌	❌	❌
İmtahanları idarə et	✅	✅	❌	❌	✅ (yalnız öz imtahanları)
Nəticələri gör	✅	✅	✅	❌	✅ (yalnız öz tələbələri)
Export (PDF/Excel)	✅	✅	✅	❌	❌
Materialları idarə et	✅	✅	❌	❌	✅ (yalnız öz materialları)
Bildiriş göndər	✅	✅	❌	❌	✅ (yalnız öz tələbəsinə, fərdi)
Elanları idarə et	✅	✅	❌	❌	❌

2.3 `lib/rbac.ts` — Bütün helper funksiyalar

```
isStaff(role)              // admin|manager|reporter|worker|teacher
canManageUsers(role)       // yalnız admin
canManageQuestions(role)   // admin|manager|worker|teacher
canManageGroups(role)      // admin|manager
canManageExams(role)       // admin|manager|teacher
canViewResults(role)       // admin|manager|reporter|teacher
canExportResults(role)     // admin|manager|reporter
canViewAnalytics(role)     // admin|manager|reporter
canUploadQuestions(role)   // admin|manager|worker
canDeleteUsers(role)       // yalnız admin
canAssignRoles(role)       // yalnız admin
canManageMaterials(role)   // admin|manager|teacher
canViewStudents(role)      // admin|manager|reporter|teacher
```

```
canSendNotifications(role) // admin|manager|teacher
canManageAds(role)         // admin|manager
```

---

3. Verilənlər Bazası Sxemi

Bütün migrasiyanlar `lib/init-db.ts` -də `ALTER TABLE ... ADD COLUMN IF NOT EXISTS` ilə həyata keçirilir — **mövcud data heç vaxt silinmir**.

`groups`

```
id TEXT PRIMARY KEY
name TEXT UNIQUE NOT NULL
created_at TIMESTAMPTZ
```

`users`

```
id TEXT PRIMARY KEY
name TEXT
email TEXT UNIQUE NOT NULL
email_verified TIMESTAMPTZ
image TEXT
password TEXT                          -- bcrypt(cost=12) hash
role TEXT DEFAULT 'student'            --
student|admin|manager|reporter|worker|teacher
group_name TEXT                        -- legacy
group_id TEXT → groups(id)
teacher_id TEXT                        -- müəllim-tələbə bağlantısı (v12)
is_blocked BOOLEAN DEFAULT false
is_student BOOLEAN DEFAULT true
last_seen_at TIMESTAMPTZ              -- heartbeat (30s interval)
deleted_at TIMESTAMPTZ                -- soft delete tarixi
deletion_reason TEXT                  -- silmə səbəbi (admin məcburi)
created_at TIMESTAMPTZ
```

`questions`

```
id INTEGER PRIMARY KEY
lecture_id INTEGER
text TEXT
type TEXT                              -- 'single' | 'multiple'
options TEXT                           -- JSON: string[]
correct_answers TEXT                   -- JSON: number[] (0-based)
difficulty TEXT                        -- 'easy' | 'medium' | 'hard'
points INTEGER
image_url TEXT
explanation TEXT                       -- imtahan bitdikdən sonra tələbəyə göstərilir
teacher_id TEXT                        -- sualın sahibi müəllim (v13); NULL =
admin/global
```

```
deleted_at TIMESTAMPTZ               -- soft delete (v13)
created_at TIMESTAMPTZ
```

`exams`

```
id TEXT PRIMARY KEY
title TEXT
group_id TEXT → groups(id)
time_limit_minutes INTEGER
is_active BOOLEAN DEFAULT false
shuffle_questions BOOLEAN DEFAULT true
shuffle_options BOOLEAN DEFAULT true
target_type TEXT DEFAULT 'all'        -- 'all' | 'student' | 'non-student'
teacher_id TEXT                       -- imtahanın sahibi müəllim (v13)
deleted_at TIMESTAMPTZ               -- soft delete (v13)
created_at TIMESTAMPTZ
```

`exam_questions` *(M2M)*

```
exam_id TEXT → exams(id) ON DELETE CASCADE
question_id INTEGER → questions(id) ON DELETE CASCADE
PRIMARY KEY (exam_id, question_id)
```

`exam_sessions`

```
id TEXT PRIMARY KEY
user_id TEXT → users(id) ON DELETE CASCADE
exam_id TEXT → exams(id)
question_order TEXT    -- JSON: number[]
option_orders TEXT     -- JSON: {[qId]: number[]}
answers TEXT DEFAULT '{}'
tab_switches INTEGER DEFAULT 0
elapsed_seconds INTEGER DEFAULT 0
started_at TIMESTAMPTZ
last_active_at TIMESTAMPTZ
status TEXT DEFAULT 'in_progress'
```

`exam_attempts`

```
id TEXT PRIMARY KEY                  -- sertifikat ID kimi istifadə edilir
user_id TEXT → users(id) ON DELETE CASCADE
exam_id TEXT → exams(id)
answers TEXT
score DOUBLE PRECISION
max_score DOUBLE PRECISION
total_questions INTEGER
correct_answers INTEGER
```

```
tab_switches INTEGER DEFAULT 0
question_order TEXT
option_orders TEXT
duration INTEGER                    -- saniyə
started_at TIMESTAMPTZ
completed_at TIMESTAMPTZ
```

materials

```
id TEXT PRIMARY KEY
title TEXT NOT NULL
content_url TEXT NOT NULL
group_id TEXT → groups(id)          -- NULL = bütün qruplar
start_date TIMESTAMPTZ DEFAULT NOW()
end_date TIMESTAMPTZ                -- NULL = limitsiz
created_by TEXT → users(id)
deleted_at TIMESTAMPTZ              -- soft delete (v13)
created_at TIMESTAMPTZ
```

messages

```
id TEXT PRIMARY KEY
sender_id TEXT → users(id) ON DELETE CASCADE
receiver_id TEXT → users(id) ON DELETE CASCADE
content TEXT NOT NULL
is_read BOOLEAN DEFAULT false
created_at TIMESTAMPTZ
```

notifications

```
id TEXT PRIMARY KEY
user_id TEXT → users(id)            -- NULL = group/all bildirişi
group_id TEXT → groups(id)          -- NULL = all bildirişi
title TEXT NOT NULL
message TEXT NOT NULL
type TEXT DEFAULT 'all'             -- 'individual' | 'group' | 'all'
is_read BOOLEAN DEFAULT false
created_at TIMESTAMPTZ
```

advertisements

```
id TEXT PRIMARY KEY
title TEXT NOT NULL
content TEXT NOT NULL
target_role TEXT DEFAULT 'all'
```

```
is_active BOOLEAN DEFAULT true
created_at TIMESTAMPTZ
```

feedbacks

```
id TEXT PRIMARY KEY
from_id TEXT → users(id) ON DELETE CASCADE
to_id TEXT → users(id) ON DELETE CASCADE
rating INTEGER                        -- 1–5 ulduz
comment TEXT
created_at TIMESTAMPTZ
```

teacher_forms

```
id TEXT PRIMARY KEY
teacher_id TEXT → users(id) ON DELETE CASCADE
title TEXT NOT NULL
questions TEXT                        -- JSON: [{text, type, options?}]
is_active BOOLEAN DEFAULT true
created_at TIMESTAMPTZ
```

teacher_form_answers

```
id TEXT PRIMARY KEY
form_id TEXT → teacher_forms(id) ON DELETE CASCADE
student_id TEXT → users(id) ON DELETE CASCADE
answers TEXT                          -- JSON: string[]
created_at TIMESTAMPTZ
```

impersonation_tokens

```
token TEXT PRIMARY KEY
admin_id TEXT → users(id) ON DELETE CASCADE
target_user_id TEXT → users(id) ON DELETE CASCADE
expires_at TIMESTAMPTZ
created_at TIMESTAMPTZ
```

activity_logs

```
id TEXT PRIMARY KEY
actor_id TEXT → users(id) ON DELETE SET NULL
actor_email TEXT
action TEXT NOT NULL
target_type TEXT
target_id TEXT
```

```
details TEXT                          -- JSON
created_at TIMESTAMPTZ
```

`login_rate_limits` ***(v15 — brute-force qorunması)***

```
email TEXT PRIMARY KEY                -- lowercase email
attempts INTEGER NOT NULL DEFAULT 1
window_start TIMESTAMPTZ NOT NULL     -- pəncərənin başlanğıcı
```

---

4. Fayl Strukturu

```
exam-portal/
├── app/
│   ├── page.tsx                        # Ana səhifə (public, sertifikat yoxlama)
│   ├── layout.tsx
│   │
│   ├── auth/
│   │   ├── signin/page.tsx             # Giriş
│   │   ├── register/page.tsx           # Qeydiyyat (3-yollu: Tələbə/Müəllim/Digər)
│   │   └── impersonate/page.tsx        # Admin impersonation
│   │
│   ├── dashboard/
│   │   ├── page.tsx                    # Tələbə kabinetı
│   │   ├── materials/page.tsx          # Tələbə materialları
│   │   ├── feedback/page.tsx           # Rəy sistemi (tələbə)
│   │   └── results/[id]/page.tsx       # Detallı nəticə + PDF/sertifikat
│   │
│   ├── messages/
│   │   ├── page.tsx
│   │   └── MessagesClient.tsx
│   │
│   ├── exam/
│   │   ├── page.tsx
│   │   └── ExamClient.tsx
│   │
│   ├── admin/
│   │   ├── page.tsx                    # Dashboard (teacher-isolated stats)
│   │   ├── users/
│   │   │   ├── page.tsx                # Teacher filter, Create button
│   │   │   ├── UserActions.tsx         # CreateUserModal (teacher dropdown),
UserRow (canBlock)
│   │   │   ├── CreateUserButton.tsx    # teacherMode prop
│   │   │   └── UsersFilterBar.tsx      # Teacher filter dropdown (v15)
│   │   ├── questions/
│   │   │   ├── page.tsx                # isAdmin + teachers props
│   │   │   └── QuestionsClient.tsx     # Teacher dropdown, bulk assign (v15)
│   │   ├── results/[id]/page.tsx
│   │   ├── exams/
│   │   ├── groups/
```

```
│   │   ├── analytics/
│   │   ├── online/page.tsx
│   │   ├── activity/page.tsx
│   │   ├── materials/
│   │   ├── notifications/
│   │   ├── advertisements/
│   │   ├── feedback/page.tsx             # Müəllim/admin rəy görünüşü
│   │   └── teacher-forms/               # Sorğu sistemi
│   │
│   └── api/
│       ├── auth/[...nextauth]/route.ts
│       ├── register/route.ts             # 3-yollu rol seçimi (v15)
│       ├── groups/route.ts
│       ├── teachers/route.ts             # Müəllim siyahısı (v12)
│       ├── admin/
│       │   ├── users/ [id]/ impersonate/ # teacher ownership check (v14)
│       │   ├── questions/
│       │   │   ├── route.ts
│       │   │   ├── [id]/route.ts         # teacherId field in PUT (v15)
│       │   │   ├── bulk-exam/route.ts
│       │   │   ├── bulk-teacher/route.ts # YENİ (v15)
│       │   │   ├── import/route.ts       # teacher sütunu (v15)
│       │   │   └── template/route.ts     # teacher sütunu (v15)
│       │   ├── exams/ [id]/
│       │   ├── groups/ [id]/
│       │   ├── materials/ [id]/
│       │   ├── notifications/
│       │   ├── advertisements/ [id]/
│       │   ├── results/ [id]/
│       │   └── export/
│       │
└── lib/
    ├── auth.ts                           # rate limit çağırışı (v15)
    ├── auth.config.ts
    ├── db.ts
    ├── init-db.ts                        # login_rate_limits cədvəli (v15)
    ├── schema.ts
    ├── rbac.ts
    ├── rate-limit.ts                     # YENİ (v15) — brute-force qorunması
    ├── pusher.ts
    ├── pusher-client.ts
    ├── scoring.ts
    └── questions.ts
```

---

5. Bütün Funksiyalar

5.1 Qeydiyyat Axışı (v15)

```
/auth/register
  ├── [Tələbə] → Qrup + Müəllim seç (məcburi)
  │              → emailVerified = null (admin/müəllim təsdiqi gözlənilir)
```

```
  │
  ├── [Müəllim] → Yalnız ad + e-poçt + şifrə
  │               → emailVerified = null (admin təsdiqi gözlənilir)
  │
  └── [Digər]  → Qrup seç
                  → emailVerified = NOW() (dərhal giriş)
```

5.2 Sual Müəllim Təyin Etmə (v15)

```
Admin → Suallar → Redaktə → "Müəllim" dropdown → Saxla
  → PUT /api/admin/questions/[id]  { teacherId: "..." }

Admin → Suallar → Çoxlu seç → "Müəllimə Təhkim Et" → Müəllim seç → Saxla
  → POST /api/admin/questions/bulk-teacher  { questionIds: [...], teacherId: "..." }

CSV import (teacher sütunu):
  teacher = "ali@test.com"   → DB-dən teacher_id tapılır
  teacher = "user_id_xxx"    → birbaşa ID kimi istifadə
  teacher = ""               → dəyişdirilmir
```

5.3 Brute-Force Qorunması (v15)

```
Login cəhdi (lib/auth.ts → authorize())
  ↓
checkLoginRateLimit(email)
  → login_rate_limits.attempts += 1 (15 dəqiqəlik pəncərədə)
  → attempts > 10 → return null (blok)
  ↓
Şifrə düzgündürsə → resetLoginRateLimit(email)
  → login_rate_limits cədvəlindən sətir silinir
```

5.4 Soft Delete (Bütün Resurslarda)

```
Resurs silinməsi heç zaman fiziki silmə etmir:
  users.deleted_at = NOW()           (+ deletion_reason məcburi)
  exams.deleted_at = NOW()
  questions.deleted_at = NOW()
  materials.deleted_at = NOW()

Auth.ts: deleted_at != null → girişi bloklayır
API: isNull(table.deletedAt) filtrini bütün GET-lərdə tətbiq edir
```

5.5 Müəllim Məlumat İzolyasiyası

```
Teacher actor bütün sorğularda filtrə məruz qalır:
  users:     WHERE teacher_id = session.user.id
  questions: WHERE teacher_id = session.user.id
  exams:     WHERE teacher_id = session.user.id
  materials: WHERE created_by = session.user.id
  results:   JOIN users WHERE users.teacher_id = session.user.id
```

```
Ownership check (403 vs 404):
  getQAndCheckOwnership(id, session)
    → q.teacherId !== session.user.id → { forbidden: true }  → 403
    → q bulunamadı                    → { forbidden: false } → 404
```

5.6 Bildiriş Sistemi

Növ	Hədəf	Pusher kanalı
`all`	Hamıya	`notifications`
`group`	Qrupa	`group-{groupId}`
`individual`	Fərdi	`private-user-{userId}`

> *Teacher yalnız `individual` tipi göndərə bilir, yalnız öz tələbəsinə.*

5.7 Real-time Arxitektura

```
Server → pusher.trigger() → Pusher cloud (ap2) → pusher-js → Browser
```

5.8 İmtahan Məntiqi

```
/exam GET
  └─ Mövcud in_progress sessiya? → davam et (elapsed_seconds bərpası)
  └─ Aktiv exam (qrupa görə, sonra global)
  └─ Shuffle suallar + seçimlər
  └─ Yeni exam_session yarat

Anti-cheat: window.blur → tabSwitches++ → DB-yə yazılır
```

5.9 PDF və Export

Fayl	URL	Giriş
Admin nəticə PDF	`GET /api/admin/export/pdf`	reporter+
Excel export	`GET /api/admin/export/results`	reporter+
Şəxsi nəticə PDF	`GET /api/user/result/[id]`	Öz nəticəsi
Sertifikat PDF	`GET /api/user/certificate/[id]`	≥70%

---

6. API Cədvəli (Tam — v15)

Public

Method	URL	Açıqlama
GET	`/api/verify/[id]`	Sertifikat doğrulama

GET	`/api/groups`	Qrup siyahısı
GET	`/api/teachers`	Müəllim siyahısı (qeydiyyat üçün)

Auth tələb edən

Method	URL	Açıqlama
POST	`/api/register`	Qeydiyyat (role: student/teacher/other)
GET,POST	`/api/messages`	Söhbət
GET	`/api/materials`	Aktiv materiallar
GET	`/api/notifications`	Bildirişlər
PATCH	`/api/notifications`	Oxundu işarələ
GET	`/api/advertisements`	Elanlar
POST	`/api/pusher/auth`	Pusher kanal auth
POST	`/api/user/heartbeat`	last_seen_at yenilə
POST	`/api/exam/save`	Cavabları saxla
POST	`/api/exam/submit`	İmtahanı bitir

Admin API

Method	URL	İcazə	Qeyd
GET,POST	`/api/admin/users`	admin/teacher	teacher öz tələbəsini yarada bilər
PUT,DELETE	`/api/admin/users/[id]`	admin/teacher	ownership check
POST	`/api/admin/users/[id]/impersonate`	admin only	
GET,POST	`/api/admin/questions`	worker+	
GET,PUT,DELETE	`/api/admin/questions/[id]`	worker+	PUT: teacherId field (v15)
POST	`/api/admin/questions/bulk-exam`	worker+	
POST	`/api/admin/questions/bulk-teacher`	admin only	YENİ (v15)
POST	`/api/admin/questions/import`	worker+	teacher sütunu (v15)
GET	`/api/admin/questions/template`	worker+	teacher sütunu (v15)
GET,POST	`/api/admin/exams`	manager+/teacher	
GET,PUT,DELETE	`/api/admin/exams/[id]`	manager+/teacher	ownership check
GET,POST	`/api/admin/groups`	manager+	

GET	`/api/admin/results`	reporter+	teacher: öz tələbələri
GET	`/api/admin/export/results`	reporter+	
GET	`/api/admin/export/pdf`	reporter+	
GET,POST	`/api/admin/materials`	teacher+	teacher: öz materialları
PUT,DELETE	`/api/admin/materials/[id]`	teacher+	ownership check
GET,POST	`/api/admin/notifications`	teacher+	teacher: yalnız fərdi
GET,POST	`/api/admin/advertisements`	manager+	
PUT,DELETE	`/api/admin/advertisements/[id]`	manager+	

---

7. Təhlükəsizlik Qeydləri

Sahə	Metod	Status
SQL Injection	Drizzle ORM parameterized queries	✅ Qorunub
XSS	React auto-escape, dangerouslySetInnerHTML yoxdur	✅ Qorunub
Sensitive Data	`.env` gitignore-da, `process.env` ilə	✅ Qorunub
Şifrə hashleme	bcryptjs cost=12	✅ Qorunub
Brute-force	`login_rate_limits` — 10 cəhd/15 dəq	✅ Qorunub (v15)
RBAC	Hər endpointdə rol yoxlaması	✅ Qorunub
Ownership	get*AndCheckOwnership() — 403 vs 404	✅ Qorunub

---

8. Mühit Dəyişənləri

```
# Neon PostgreSQL
DATABASE_URL=postgresql://user:pass@host/db?sslmode=require

# NextAuth
AUTH_SECRET=random-32-char-string
AUTH_URL=http://localhost:3000
NEXTAUTH_URL=https://exam-portal-nine-azure.vercel.app

# Pusher (ap2 cluster)
PUSHER_APP_ID=2149059
PUSHER_KEY=a11d4fbad3508c00e265
PUSHER_SECRET=1bad7423ee063bae67ed
PUSHER_CLUSTER=ap2
NEXT_PUBLIC_PUSHER_KEY=a11d4fbad3508c00e265
NEXT_PUBLIC_PUSHER_CLUSTER=ap2
```

```
# Admin seed
ADMIN_EMAIL=admin@exam.local
ADMIN_PASSWORD=Admin@123
ADMIN_NAME=Admin
```

---

9. Deployment (Vercel)

1. GitHub `master` branch-a push → Vercel avtomatik deploy
2. Vercel Dashboard → Settings → Environment Variables-a yuxarıdakıları əlavə et
3. İlk deploy: `instrumentation.ts` → `initDatabase()` — bütün cədvəllər, sütunlar yaranır
4. Mövcud data toxunulmur: `ALTER TABLE ... ADD COLUMN IF NOT EXISTS`

---

10. Əsas Qeydlər

- **Mövcud data qorunur:** Bütün migrasiyanlar `IF NOT EXISTS` ilə — heç bir sətir silinmir
- **Soft delete hər yerdə:** `deleted_at` — admin silmə səbəbi məcburi; hard delete yoxdur
- **Teacher izolyasiyası:** Hər resurs endpoint-ində `WHERE teacher_id = session.user.id`
- **Brute-force:** 10 uğursuz cəhd → 15 dəqiqə blok (DB-də izlənilir, Vercel-ə uyğun)
- **Heartbeat:** hər 30s `POST /api/user/heartbeat`
- **Pusher cluster:** ap2 (Asia Pacific)
- **Sertifikat ID:** `exam_attempts.id` (UUID)